🏛️ Arquitectura del Sistema — LegalprojectIA

Plataforma de Workflow para Revisión Jurídica con Inteligencia Artificial (SaaS)

Organización Patrocinadora: PluriOne S.A. de C.V. (Develop Talent & Technology)
Institución Académica: Instituto Tecnológico Superior de Atlixco (ITSA) — Residencia Profesional
Estado del Proyecto: Etapa Terminal / Listo para Producción (Release Candidate)
URL de Producción: https://legaltech-api-LegalprojectIA-1134.azurewebsites.net

📑 Tabla de Contenidos

1. Visión General
2. Diagrama de Arquitectura en la Nube (Microsoft Azure)
3. Diagrama C4: Contenedores y Flujo de Información
4. Máquina de Estados del Workflow BPM
5. Orquestación de Inteligencia Artificial y Extracción Documental
6. Modelo de Seguridad, Identidad y RBAC
7. Esquema de Base de Datos y Persistencia
8. Integración Analítica y Power BI

🌐 1. Visión General

LegalprojectIA es una plataforma corporativa desarrollada en arquitectura de tres capas modulares diseñada para automatizar, agilizar y auditar el ciclo de vida completo de documentos legales (contratos mercantiles, convenios de confidencialidad NDA, adendas, poderes notariales y políticas internas).

La plataforma combina:

- **Gestor BPM (Business Process Management):** Asignación automática por carga activa de trabajo, transiciones estrictas de estado y trazabilidad legal.
- **Inteligencia Artificial Especializada:** Azure OpenAI (`gpt-5-mini` / `gpt-4o-mini`) con prompts jurídicos densos y OCR inteligente mediante Azure AI Document Intelligence y PyMuPDF.
- **Seguridad Grado Corporativo:** Autenticación federada mediante Microsoft Entra ID (SSO), control de acceso basado en roles (RBAC), firmas digitales con hash inmutable SHA-256 y cifrado en reposo AES-256-GCM.
- **Inteligencia de Negocio:** Tableros analíticos en Microsoft Power BI conectados a vistas SQL optimizadas y endpoints REST seguros.

☁️ 2. Diagrama de Arquitectura en la Nube (Microsoft Azure)

El sistema opera completamente sobre servicios gestionados (PaaS) de Microsoft Azure en esquema *Turnkey Zero-Touch*:

```
[DIAGRAMA DE ARQUITECTURA / FLUJO]

flowchart TD
    subgraph Internet["Usuarios y Clientes Externos"]
        UserBrowser["Navegador Web\n(Abogado / Aprobador / Auditor / Admin)"]
        PowerBIApp["Power BI Desktop / Service\n(DirectQuery / Web Feed)"]
    end

    subgraph AzureCloud["Microsoft Azure (Resource Group)"]
        subgraph EntraID["Microsoft Entra ID"]
            AppReg["App Registration\n(Multi-tenant OAuth2 / OIDC)"]
        end

        subgraph Compute["Capa de Cómputo & Aplicación"]
            AppService["Azure App Service (Linux)\nFastAPI Backend + Jinja2 UI + SQLAdmin"]
        end

        subgraph StorageData["Capa de Persistencia & Almacenamiento"]
            PostgreSQL[("Azure Database for PostgreSQL\nFlexible Server (v16)\nlegaltech_db")]
            BlobStorage["Azure Blob Storage\nContenedor: 'documentos'\n(Cifrado SSE / TLS 1.2)"]
        end

        subgraph AIServices["Capa Cognitiva de Inteligencia Artificial"]
            OpenAI["Azure OpenAI Service\n(gpt-5-mini / text-embedding)"]
            DocIntelligence["Azure AI Document Intelligence\n(Layout OCR / Detección de Tablas)"]
            AISearch["Azure AI Search\n(Indexación Vectorial / Semántica)"]
        end
    end

    UserBrowser -->|HTTPS / TLS 1.3| AppService
    UserBrowser -.->|Autenticación SSO MSAL| AppReg
    PowerBIApp -->|Conexión Segura SQL o REST| PostgreSQL
    PowerBIApp -->|Feed JSON Tabular| AppService

    AppService -->|SQLAlchemy 2.0 / Pool SSL| PostgreSQL
    AppService -->|Azure SDK Blob Client| BlobStorage
    AppService -->|Chat Completions API| OpenAI
    AppService -->|Analyze Document Layout API| DocIntelligence
    AppService -->|Search & Query API| AISearch
    AppService -->|Token Validation & Claims| AppReg
```

🧱 3. Diagrama C4: Contenedores y Flujo de Información

La siguiente vista de contenedores detalla la organización interna de la aplicación:

```
[DIAGRAMA DE ARQUITECTURA / FLUJO]

graph TB
    subgraph Client["Frontend Ligero (Server-Side + JS Nativo)"]
        UI["Plantillas Jinja2 + TailwindCSS + Lucide Icons\n(Sin frameworks pesados, 100% responsivo)"]
        AuthJS["MSAL.js Bundle Local\n(Inicio de Sesión Entra ID sin dependencias CDN)"]
    end

    subgraph API["FastAPI Application Core"]
        SecurityMiddleware["Middlewares Transversales:\n• Rate Limiter (Token Bucket)\n• OWASP Security Headers & Anti-
Fingerprinting\n• Payload Size Limiter (20MB)"]

        Router["API Router (/api/v1)"]

        subgraph Endpoints["Endpoints Modulares"]
            EP_Auth["auth.py (Sesión, Tokens, Logout)"]
            EP_Solicitudes["solicitudes.py (Expedientes, Folios)"]
            EP_Workflows["workflows.py (Inbox, Tareas, BPM)"]
            EP_Docs["documents.py (Subida, Versiones)"]
            EP_Reviews["reviews.py (Dictámenes, Comentarios)"]
            EP_Sigs["signatures.py (Firmas Electrónicas)"]
            EP_AI["ai_legal.py (Asistente Legal, Riesgos)"]
            EP_Analytics["analytics.py (KPIs, Cuellos de Botella)"]
            EP_Audit["audit.py (Trazabilidad Forense)"]
            EP_Admin["admin.py (SQLAdmin ORM Panel)"]
            EP_Users["users.py (Usuarios y Roles)"]
        end

        subgraph CoreServices["Servicios y Lógica de Negocio"]
            WFEngine["WorkflowEngine\n(Balanceo de carga y transiciones)"]
            Extractor["DocumentExtractor\n(PyMuPDF nativo + Fallback Azure OCR)"]
            AIService["LegalAIService\n(Azure OpenAI con optimización de tokens)"]
            CryptoService["Security Core\n(AES-256-GCM Cifrado / SHA-256 Hashing)"]
            AuditHelper["AuditHelper\n(Registro inmutable de trazabilidad)"]
        end
    end

    UI --> SecurityMiddleware
    AuthJS --> EP_Auth
    SecurityMiddleware --> Router
    Router --> Endpoints
    Endpoints --> CoreServices
```

🔄 4. Máquina de Estados del Workflow BPM

Cada solicitud de revisión jurídica transita por un ciclo de vida estrictamente regulado por el motor `WorkflowEngine` (`app/services/workflow_engine.py`):

```
[DIAGRAMA DE ARQUITECTURA / FLUJO]

stateDiagram-v2
    [*] --> BORRADOR: Creación de Solicitud (Usuario Jurídico)
    BORRADOR --> EN_REVISION: Envío Formal a Revisión

    state EN_REVISION {
        [*] --> AsignacionAutomatica: Balanceo por menor carga activa
        AsignacionAutomatica --> AnalisisDocumental: Extracción y Lectura
        AnalisisDocumental --> DictamenRevisor: Evaluación Jurídica + Asistencia IA
    }

    EN_REVISION --> OBSERVADO: Revisor detecta cláusulas de riesgo o inconsistencias
    OBSERVADO --> EN_REVISION: Usuario carga nueva versión corregida (v2, v3...)

    EN_REVISION --> EN_APROBACION: Revisor emite dictamen favorable

    state EN_APROBACION {
        [*] --> RevisionAprobador: Evaluación por Aprobador Jurídico
        RevisionAprobador --> DecisionFormal
    }

    EN_APROBACION --> APROBADO: Aprobador ratifica dictamen
    EN_APROBACION --> RECHAZADO: Aprobador dictamina inviabilidad

    APROBADO --> FIRMADO: Registro de Firma Electrónica con Hash Criptográfico

    FIRMADO --> [*]
    RECHAZADO --> [*]
```

Reglas de Negocio en las Transiciones:

- **RN-001 (Balanceo Equitativo):** Al ingresar al estado `EN_REVISION`, el sistema calcula el número de solicitudes activas de cada abogado con rol `REVISOR_JURIDICO` y asigna automáticamente la solicitud al que tenga la menor carga de trabajo.
- **RN-004 (Inmutabilidad de Versiones):** Cada ajuste tras una observación no sobrescribe el archivo anterior; crea un nuevo registro inmutable en `VersionDocumento` con su propio hash SHA-256 y marca el anterior como histórico.
- **RN-008 (Supervisión Humana Obligatoria):** La Inteligencia Artificial genera dictámenes preliminares y semaforización de riesgos, pero únicamente un usuario humano con rol `REVISOR_JURIDICO` o `APROBADOR_JURIDICO` puede validar y cambiar el estado formal de la solicitud.
- **RN-010 (Trazabilidad Mandatoria):** Cada transición genera automáticamente una entrada en la tabla `Auditoria` registrando usuario, rol, IP de origen, fecha/hora y detalle del cambio.

🧠 5. Orquestación de Inteligencia Artificial y Extracción Documental

La plataforma implementa un pipeline híbrido de procesamiento de lenguaje natural y visión computacional:

```
[DIAGRAMA DE ARQUITECTURA / FLUJO]

sequenceDiagram
    autonumber
    actor Abogado as Abogado Revisor
    participant UI as Portal Web (legal_review.html)
    participant API as Endpoint (/api/v1/ai/query)
    participant Extractor as DocumentExtractor (PyMuPDF)
    participant AzureOCR as Azure Document Intelligence
    participant OpenAI as Azure OpenAI (gpt-5-mini)

    Abogado->>UI: Clic en "Analizar Cláusulas con IA"
    UI->>API: POST /api/v1/ai/query (solicitud_id, prompt)

    activate API
    API->>Extractor: Extraer texto digital del documento
    alt Documento Digital Nativo
        Extractor-->>API: Texto limpio extraído (0.05 segundos)
    else Documento Escaneado / Imagen (Fallback)
        Extractor->>AzureOCR: Enviar stream binario a OCR Layout
        AzureOCR-->>Extractor: Texto OCR con preservación de tablas
        Extractor-->>API: Texto estructurado completo
    end

    API->>OpenAI: Enviar System Prompt Jurídico + Texto Documento + Pregunta
    Note over OpenAI: Parámetros optimizados:
completion_tokens=1000
reasoning_effort=low
temperature=0.1
    OpenAI-->>API: Dictamen estructurado (Riesgos, Cláusulas, Recomendaciones)
    API-->>UI: Respuesta JSON sanitizada con referencias legales
    deactivate API
    UI-->>Abogado: Renderizado interactivo en panel lateral
```

🔐 6. Modelo de Seguridad, Identidad y RBAC

1. Autenticación Federada con Microsoft Entra ID

- Implementación de Single Sign-On (SSO) mediante MSAL (Microsoft Authentication Library).
- Soporte para esquemas **Multi-Tenant** (cualquier cuenta educativa o corporativa de Microsoft) y restricción opcional **Single-Tenant**.
- Auto-aprovisionamiento seguro de usuarios (*Just-In-Time Provisioning*) al iniciar sesión por primera vez.

2. Matriz de Control de Acceso Basado en Roles (RBAC)

La aplicación cuenta con 4 roles formalmente separados a nivel de endpoint mediante el decorador `@requiere_roles(...)`:

RECURSO / MÓDULO	REVISOR JURÍDICO	APROBADOR JURÍDICO	ADMINISTRADOR	AUDITOR
Dashboard y Métricas	✅	✅	✅	✅
Mis Tareas (Inbox Personal)	✅	✅	✅	❌
Crear Nueva Solicitud	✅	✅	✅	❌
Revisar y Emitir Dictamen	✅	❌	✅	❌
Comentar en Hilos	✅	✅	✅	❌
Aprobar / Rechazar Solicitud	❌	✅	✅	❌
Registrar Firma Electrónica	❌	✅	✅	❌
Historial de Versiones	✅	✅	✅	❌
Bitácora de Auditoría Forense	❌	❌	✅	✅
Gestión de Usuarios y Roles	❌	❌	✅	❌
Panel SQLAdmin (ORM Directo)	❌	❌	✅	❌
Reportes y Feed Power BI	❌	❌	✅	✅

3. Cifrado Criptográfico

- **Cifrado en Reposo (AES-256-GCM):** Los campos clasificados como confidenciales en la base de datos se cifran utilizando una clave de 256 bits y un vector de inicialización único (nonce de 12 bytes) por cada registro.
- **Sellado e Integridad (SHA-256):** Toda versión de contrato genera un hash criptográfico de 64 caracteres hexadecimales para garantizar la imposibilidad de repudio y la detección de cualquier alteración en el archivo.

🗄️ 7. Esquema de Base de Datos y Persistencia

El almacenamiento relacional reside en **PostgreSQL 16** gestionado mediante **SQLAlchemy 2.0** y migraciones controladas por **Alembic**:

[DIAGRAMA DE ARQUITECTURA / FLUJO]

```
erDiagram
    USUARIO ||--o{ SOLICITUD_REVISION : "crea"
    USUARIO ||--o{ SOLICITUD_REVISION : "revisa (asignado)"
    SOLICITUD_REVISION ||--|{ DOCUMENTO : "contiene"
    DOCUMENTO ||--|{ VERSION_DOCUMENTO : "versiona"
    SOLICITUD_REVISION ||--o{ COMENTARIO : "posee hilos"
    COMENTARIO ||--o{ COMENTARIO : "responde a (parent_id)"
    SOLICITUD_REVISION ||--o{ FIRMA : "formaliza"
    SOLICITUD_REVISION ||--o{ AUDITORIA : "registra eventos"
    USUARIO ||--o{ NOTIFICACION : "recibe"
    WORKFLOW ||--o{ ETAPA_WORKFLOW : "define pasos"

    USUARIO {
        int id PK
        string oid_azure UK
        string email UK
        string nombre_completo
        string rol
        boolean activo
    }

    SOLICITUD_REVISION {
        int id PK
        string folio UK
        string titulo
        string estado
        string prioridad
        int usuario_creador_id FK
        int abogado_asignado_id FK
        datetime fecha_limite_sla
    }

    DOCUMENTO {
        int id PK
        int solicitud_id FK
        string nombre_archivo
        string url_blob
        int version_actual
    }

    VERSION_DOCUMENTO {
        int id PK
        int documento_id FK
        int numero_version
        string sha256_hash
        string url_blob
    }

    COMENTARIO {
        int id PK
        int solicitud_id FK
        int usuario_id FK
        int parent_id FK
        text contenido
    }

    FIRMA {
        int id PK
        int solicitud_id FK
        int usuario_id FK
        string firma_hash
        datetime fecha_firma
    }
```

```
    AUDITORIA {
        int id PK
        int usuario_id FK
        string accion
        string entidad
        string ip_origen
        datetime timestamp
    }
```

📊 8. Integración Analítica y Power BI

La plataforma expone dos mecanismos para el consumo de datos ejecutivos:

1. **Vistas SQL Pre-optimizadas:**
   - `vw_powerbi_solicitudes_kpi` : Métricas de duración, cumplimiento de SLA, estado y tiempos de ciclo.
   - `vw_powerbi_cuellos_botella` : Densidad de trabajo por abogado revisor y detección de retrasos.
   - `vw_powerbi_trazabilidad` : Resumen cronológico de eventos para auditoría de cumplimiento.
2. **Endpoint REST API Segura (`/api/v1/analytics/powerbi-feed`):**
   - Retorna un payload JSON tabular aplanado para su consumo en Power BI Service sin requerir abrir el puerto 5432 de la base de datos a internet, protegido por `X-API-KEY` o token Bearer Entra ID.